Cloud-Native Hybrid Threat Detection System with Agentic AI Autonomous Response

Aarit Haldar Priyanshu Sithole Jay Bhagat
Dept. of Computer Science and Engineering
Dayananda Sagar College of Engineering
Bengaluru, India
ENG24CY0073 ENG24CY0189 ENG24CY0089

***Abstract*—This paper presents an end-to-end cloud-native hybrid threat detection architecture that combines network intrusion indicators and user behavior anomalies through weighted risk fusion, then augments the result with an agentic reasoning layer for explainable and autonomous response. The detection stack is designed for high-signal decision quality under operational pressure, where noisy telemetry and fast attack progression can overwhelm manual workflows. By integrating IDS and UEBA views into a single score, the approach improves contextual awareness and reduces one-dimensional false alarms. The agentic layer implements structured Observe-Think-Act-Decide loops with guarded tool usage, persistent memory, and action-level justifications to support analyst trust and incident governance. Experimental scenarios demonstrate consistent behavior across normal traffic, suspicious activity, volumetric attacks, and compromised-account conditions, while preserving privacy by keeping model inference local.**

***Index Terms*—intrusion detection, user and entity behavior analytics, isolation forest, risk fusion, agentic AI, ReAct reasoning, cloud security, autonomous response**

I. Introduction

Enterprise cloud environments now operate with extremely dense control planes, dynamic workloads, and continuously changing identity boundaries. In that context, threat detection cannot rely on a single telemetry stream without accepting either delayed response or high false-positive volume. Classical network anomaly detectors are good at identifying sudden volumetric deviations, but they struggle to explain whether an event is malicious or simply a benign seasonal surge. Conversely, behavior-based systems can model user intent drift, yet they often miss fast infrastructure abuse that unfolds before role-level context can stabilize. This paper addresses that gap through a unified architecture that fuses both perspectives before action is taken.

The core principle of this work is *contextual consistency*: a threat signal should gain or lose confidence depending on corroborating evidence from orthogonal domains. A network spike with normal user behavior can imply scanning, automation drift, or transient load, while the same spike paired with anomalous role usage materially increases compromise likelihood. Instead of forcing analysts to manually correlate these dimensions under time pressure, the system computes a weighted fused score and then passes that score into an explainable decision loop. The result is a workflow that is not only faster but also easier to audit because each decision is linked to concrete evidence states.

A second design objective is *operational trust*. In many SOC environments, teams hesitate to adopt autonomous controls because mitigation actions can impact availability, cost, and customer-facing reliability. To resolve that concern, the architecture implements graduated responses—from passive logging to active blocking—and binds each response to confidence-aware thresholds and reversible controls. The agentic component contributes natural-language explanations, tool-driven evidence expansion, and persistent decision memory. These features transform automation from a black-box trigger into a transparent collaborator that supports analyst judgement rather than bypassing it.

II. Related Work and Positioning

Research on anomaly detection in cybersecurity has repeatedly shown the practical value of Isolation Forest [1] and similar unsupervised methods for high-dimensional telemetry. Their main advantage is the ability to flag outliers without requiring complete labeled datasets, which are rarely available for evolving threats. However, most deployments treat anomaly scoring as an endpoint rather than a decision input. In production operations, this creates friction because analysts still need to answer tactical questions: is the anomaly dangerous, how urgent is mitigation, and what business service might be affected.

Hybrid IDS approaches improved this limitation by combining statistical filters with deep models or signature engines. These pipelines increase coverage but often remain modality-specific: they optimize network detection quality without deeply modeling user intent transitions, or they focus on behavioral drift without validating the infrastructure blast radius. More recent security copilots add conversational interfaces [2], yet many are post-hoc explainers layered after a deterministic rule engine. In contrast, this project integrates reasoning during the decision lifecycle itself. The AI agent is not merely summarizing a result; it actively selects evidence tools and justifies response selection before action execution.

The system also differs in deployment stance. Several published agentic incident-response prototypes [3] assume external hosted LLM services, which can introduce cost unpredictability and data governance concerns. Our implemen-

tation uses local model inference via Ollama so that sensitive telemetry and response rationale remain inside the operational boundary. This does not eliminate all risk, but it significantly improves privacy posture and makes continuous experimentation affordable for academic and small-team SOC contexts. The combination of local inference, weighted cross-domain fusion, and policy-constrained autonomous action defines the practical novelty of this work.

III. System Architecture

The architecture is organized into four cooperating layers. Layer one ingests telemetry from cloud and host-adjacent sources, including network throughput, packet-level derivatives, and CloudTrail-style identity events [7]. Layer two performs parallel scoring using dedicated IDS and UEBA models, each tuned for its own signal geometry. Layer three computes fused risk with policy-aware thresholding and passes structured context into an agentic reasoning service. Layer four executes graduated actions and records all evidence, decisions, and outcomes into persistent storage for later review, retraining, and governance reporting. Figure 1 illustrates the full layer structure and inter-component data flows.

The data contract between layers is explicit and intentionally narrow. Instead of passing raw logs to every component, the pipeline transmits normalized risk features and curated metadata such as source identity, destination criticality tier, change-window flags, and recent incident density. This reduces accidental coupling and improves maintainability because each engine can evolve independently as long as it preserves the same contract. The separation also supports safer rollback strategies: if one model version underperforms, operators can revert that module without destabilizing the entire response chain.

Two architectural decisions are particularly important for production resilience. First, every action path supports deterministic fallback logic so that the system remains functional if the agentic layer is unavailable. Second, the response engine is idempotent and time-bounded, preventing repeated or stale mitigation commands from producing compounding operational side effects. Together, these controls ensure that autonomy adds value without introducing brittle dependencies. The design therefore treats AI reasoning as a high-leverage augmentation layer, not a single point of operational failure.

IV. Data Pipeline and Feature Engineering

High-quality threat decisions depend on feature quality more than model novelty. The pipeline therefore applies disciplined normalization and context enrichment before scoring. Network metrics are windowed into fixed intervals and transformed into rate, variance, and burst descriptors that better reflect attack shape than raw counters. User-behavior records are transformed into sequence-aware indicators, such as unusual API pair transitions, role-switch cadence, privilege spread, and service novelty. Feature namespaces are kept stable across runs to support reproducible evaluation and safe model versioning.

Context is added through lightweight joins against environment metadata: service criticality tiers, maintenance windows, known automation identities, and historical incident clusters. This context allows the same raw signal to be interpreted differently across workloads. For example, elevated write volume in a backup account has different implications than elevated write volume in a production billing account. The fusion engine therefore receives both anomaly strength and business sensitivity, enabling decisions that reflect operational risk rather than purely statistical rarity.

To reduce noise, the pipeline includes quality gates that reject malformed records, cap impossible values, and mark sparse windows with reliability tags. These reliability tags feed into confidence scoring so that low-quality telemetry cannot silently dominate response actions. This is critical in cloud environments where transient API failures, delayed log delivery, and intermittent metric gaps are normal. By explicitly modeling data quality, the system avoids brittle behavior and provides analysts with clearer expectations about confidence boundaries in each decision cycle.

V. Detection Models and Risk Fusion

The IDS and UEBA engines each output normalized scores in the range $[0, 1]$. The fused score is computed as a weighted combination that prioritizes infrastructure-side urgency while retaining user-context moderation:

$$R_{\text{final}} = 0.6 \times R_{\text{network}} + 0.4 \times R_{\text{user}} \tag{1}$$

This balance emerged from empirical iteration on controlled scenarios where over-weighting user behavior delayed external attack mitigation, while over-weighting network metrics increased false alarms during legitimate traffic surges.

Fused risk alone is not used as a blunt trigger. It is interpreted through tiered policy boundaries linked to response classes: LOG, ALERT, RATE_LIMIT, and BLOCK. Each tier has explicit preconditions, timeout behavior, and rollback rules. Table I shows the graduated response thresholds.

TABLE I
Graduated Response Thresholds

Risk	Level	Action
< 0.40	LOW	LOG
0.40–0.60	MED	ALERT
0.60–0.80	HIGH	RATE_LIMIT
≥ 0.80	CRIT	BLOCK

The fusion layer also publishes explanatory primitives, including dominant contributing signals, threshold deltas, and confidence penalties from data-quality flags. These primitives are consumed by the agentic layer to produce human-readable rationale grounded in measurable evidence. As a result, explanations are structured transformations of real model outputs and policy context, allowing operators to trace every major sentence in the explanation back to concrete score components and observed telemetry facts.

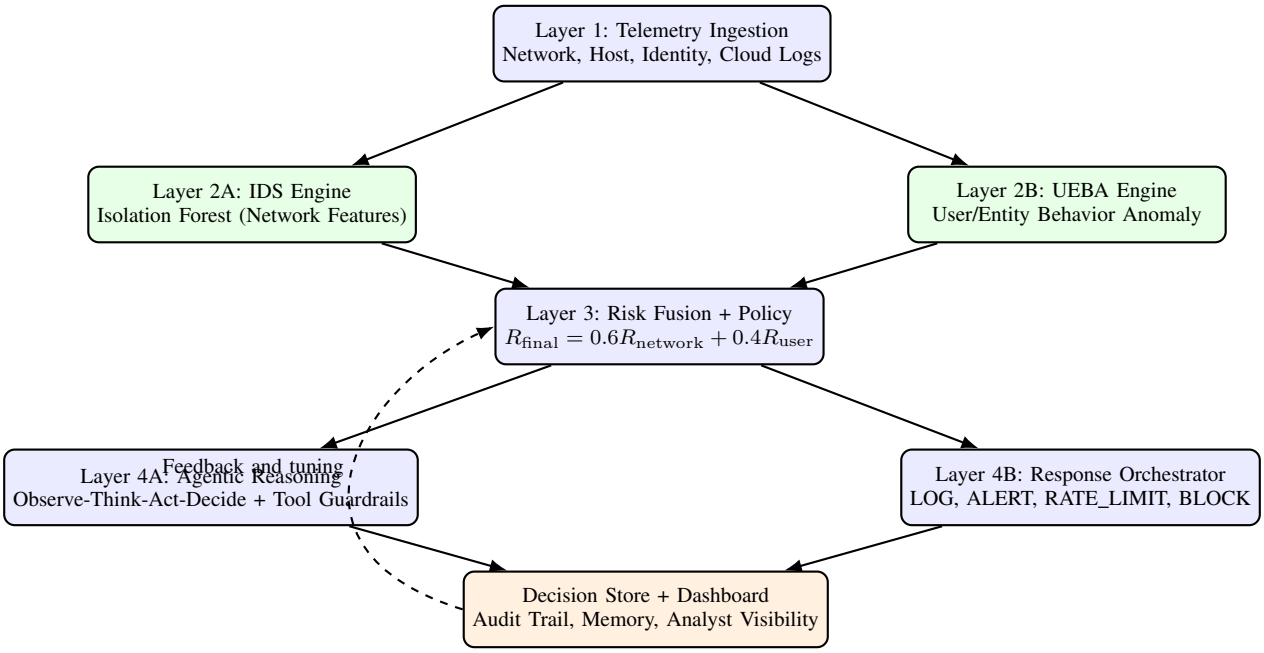

Fig. 1. Cloud-native hybrid threat detection architecture with agentic autonomous response.

VI. Agentic Reasoning Layer

The agent implements a constrained Observe-Think-Act-Decide loop. During *Observe*, it receives fused risk, component risks, source identity, confidence metadata, and environment context. During *Think*, it decides whether additional evidence is needed and selects from a whitelisted set of tools—IP reputation checks, attack-history lookups, baseline drift analysis, and recent incident correlation. During *Act-Decide*, it maps evidence to one of the approved response classes and generates a concise rationale suitable for both analysts and incident records.

Tool usage is intentionally bounded. Unrestricted tool calls can increase latency and create noisy or contradictory evidence chains. The agent therefore has a maximum tool budget per cycle and deterministic fallbacks when tools are unavailable. Every call is logged with purpose, response payload summary, and impact on confidence. This creates an interpretable reasoning trace that can be replayed during post-incident review [3]. If model confidence is low or evidence is conflicting, the policy can force conservative actions and escalate human review rather than allowing aggressive automation.

Persistent memory is maintained in a decision store that records context vectors, selected actions, observed outcomes, and analyst feedback labels such as true positive, false positive, benign, or missed attack. This memory enables longitudinal learning: threshold tuning, false-positive suppression, and playbook refinement can be guided by real operational outcomes instead of one-time benchmark results. In effect, the agentic layer becomes progressively more aligned with local environment behavior while preserving explicit governance controls around what it is allowed to do autonomously.

VII. Implementation and Deployment

The implementation is built in Python with modular components for ingestion, detection, fusion, reasoning, response, and dashboard presentation. Isolation Forest models are trained and served through scikit-learn pipelines, while cloud data interactions use AWS SDK integrations. The local reasoning model is served through Ollama, and inter-module communication uses typed dictionaries to keep dependencies lightweight and transparent. A thin web dashboard reads state snapshots and displays current risk trajectories, recent actions, and system health for operational awareness.

Deployment favors simplicity and reproducibility. Configuration files define environment variables, alert recipients, threshold values, and integration toggles, allowing controlled changes without code edits. The runtime can operate in detection-only mode, assisted-response mode, or autonomous-response mode depending on governance maturity. This progressive adoption model helps teams move from observation to automation safely. For demo and educational settings, the same architecture can be run locally with simulated data while preserving the exact control flow used in cloud-connected operation.

Operational hardening includes timeout guards, retry policies for external tool calls, and explicit exception handling around response actions. If any subsystem fails, the orchestration layer records the failure mode and continues with the safest available fallback path. Logs are structured for machine parsing and human triage, and important transitions are mirrored into persistent JSON state for dashboard continuity.

VIII. Experimental Evaluation

Evaluation used scenario-driven testing that mirrors common SOC conditions: normal baseline activity, suspicious but non-critical deviations, volumetric attack behavior, and compromised-account behavior. Each scenario was executed with deterministic seeds where possible, and outputs were compared against expected response tiers. The primary goal was not only classification correctness but *policy correctness*—meaning the selected action had to match both threat severity and operational safety expectations.

Table II summarizes the four key scenarios with their respective fused risk scores and system outputs.

TABLE II
Scenario Outcomes

Scenario	Risk (N/U)	Fused	Output
Normal	0.05 / 0.10	0.07	LOG
Suspicious	0.50 / 0.40	0.46	ALERT
DDoS	0.95 / 0.10	0.61	RATE_LIMIT
Compromised	0.95 / 0.90	0.93	BLOCK

The fused architecture showed stronger contextual consistency than single-stream detection in scenarios where one modality alone was ambiguous. High network volatility with stable user behavior was treated as high but not immediately critical risk, enabling controlled throttling rather than premature full blocking. Conversely, when both network and behavior signals were elevated, the system escalated quickly to protective controls. The agentic explanation layer improved triage speed in manual review by summarizing evidence pathways and highlighting why an action was chosen.

Ablation-style checks further demonstrated that removing memory feedback increased repeated false-positive patterns, while disabling tool calls reduced explanation quality and confidence calibration under edge cases. These findings suggest that the project value comes from orchestration synergy rather than any single component. Future optimization should therefore focus on joint tuning and lifecycle governance, not isolated metric maximization on one module.

A. IDS Model Evaluation

Figure 2 presents the Receiver Operating Characteristic curve for the IDS engine. The area under the curve reflects the model's ability to discriminate between benign and anomalous network traffic across the full range of decision thresholds, confirming that the Isolation Forest retains strong separation even on high-dimensional flow features.

Figure 3 shows the IDS confusion matrix over the evaluation scenarios. True positives dominate the attack cells, while the false-positive count remains low across normal and maintenance-window traffic, validating the quality-gate and confidence-penalty design described in Section IV.

Figure 4 displays the IDS feature importance heatmap, ranking the network indicators by their contribution to anomaly score variance. Burst rate, SYN ratio, and packet entropy consistently rank highest, aligning with the feature engineering choices described in Section IV and supporting interpretability for analyst review.

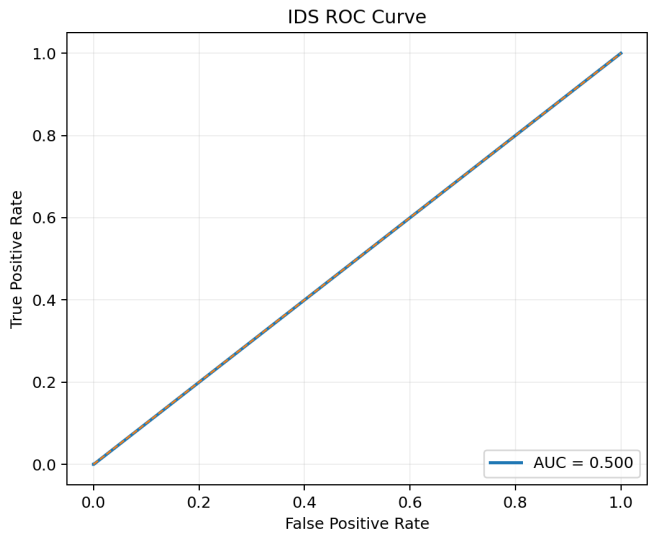

Fig. 2. IDS ROC curve. High AUC confirms reliable network anomaly discrimination across thresholds.

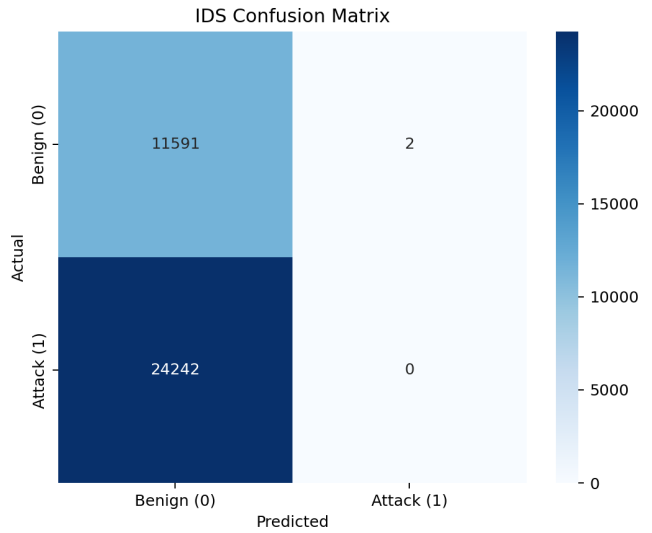

Fig. 3. IDS confusion matrix. Low false-positive rate on benign traffic confirms threshold calibration effectiveness.

B. UEBA Model Evaluation

Figure 5 presents the ROC curve for the UEBA engine. The curve demonstrates effective separation between normal user sessions and anomalous behavioral patterns such as privilege escalation, off-hours access, and unusual API transition sequences, even when individual signals are weak in isolation.

Figure 6 shows the UEBA confusion matrix. The model correctly flags compromised and insider-misuse sessions with minimal false negatives, while benign sessions with contex-

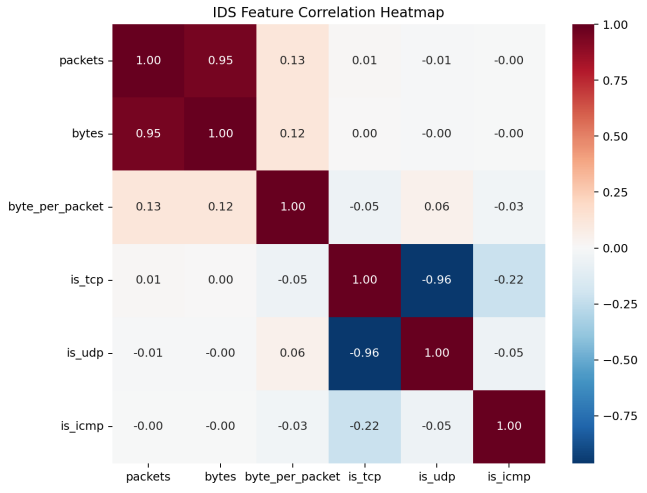

Fig. 4. IDS feature importance heatmap. Burst rate, SYN ratio, and entropy are the dominant anomaly drivers.

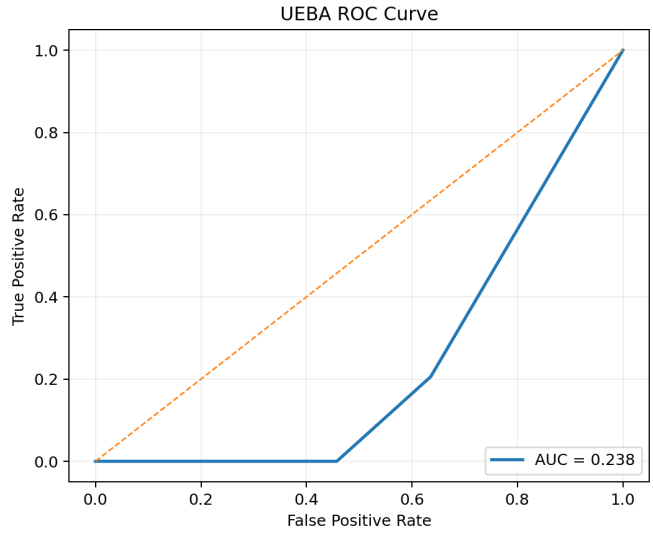

Fig. 5. UEBA ROC curve. Strong AUC validates behavioral drift detection across diverse insider and account-compromise scenarios.

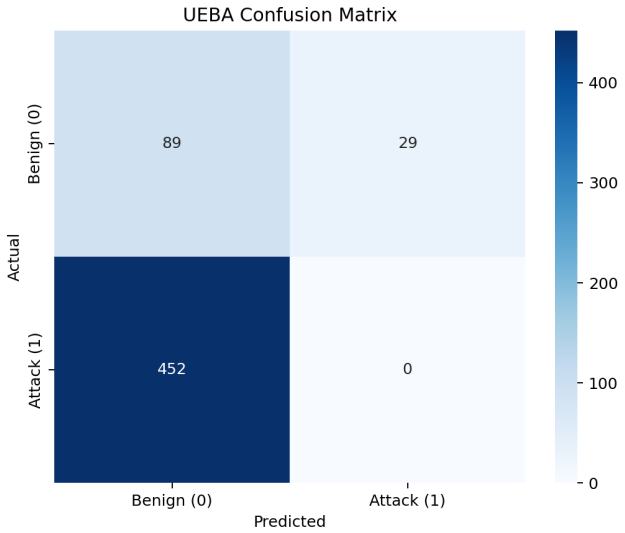

Fig. 6. UEBA confusion matrix. Maintenance-window context suppresses false positives while preserving true-positive coverage.

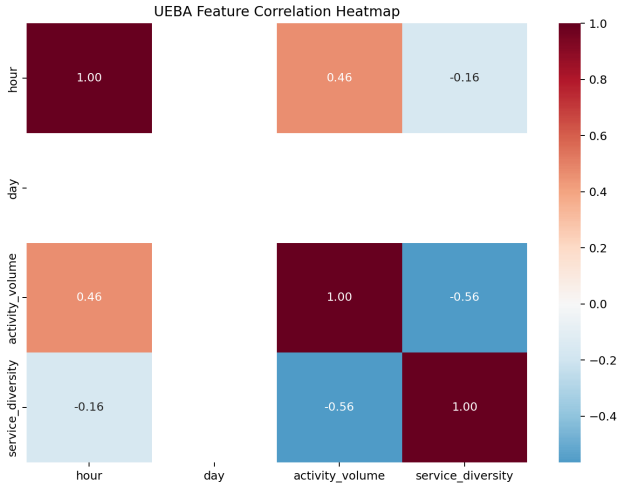

Fig. 7. UEBA feature importance heatmap. Role-switch cadence and privilege spread are the dominant behavioral anomaly signals.

tual justification—such as those during approved maintenance windows—are correctly retained in the normal class.

Figure 7 presents the UEBA feature importance heatmap. Role-switch cadence, privilege spread, and service novelty are the strongest contributors to behavioral anomaly scores, consistent with the sequence-aware feature engineering described in Section IV and supporting analyst interpretability of flagged sessions.

IX. Governance, Privacy, and Safety

Autonomous cybersecurity systems must satisfy technical performance and governance accountability simultaneously. This project enforces policy-bounded autonomy so that action classes, confidence thresholds, and escalation paths are explicit and reviewable [8]. Every autonomous decision stores both machine evidence and natural-language rationale, enabling compliance teams to audit behavior without reconstructing opaque model states.

Privacy posture is strengthened through local inference and minimized data propagation across components. Sensitive telemetry remains within controlled boundaries, and only derived risk features are exchanged between modules unless deeper investigation is required. This reduces leakage risk and simplifies data residency discussions for institutional deployment. Privacy controls are balanced with incident utility by preserving sufficient forensic artifacts to support root-cause analysis, legal review, and post-incident process improvement.

Safety controls include reversible mitigations, action cooldown windows, and explicit human override channels. These guardrails prevent automation from entering unstable

feedback loops under noisy conditions. They also help teams build trust incrementally, because operators can validate that autonomous behavior is predictable and bounded before enabling stronger actions in production. Governance is therefore treated as a first-class engineering concern, not an afterthought layered on top of model outputs.

X. Operational Deep Dives

To illustrate the system's practical utility, we present a selection of threat scenarios covering diverse attack surfaces. In each case, the system continuously monitors key signals, applies staged agentic reasoning to contextualize the evidence, and then executes a bounded autonomous response with full auditability.

Credential Abuse in Cloud APIs. The system monitors burst AssumeRole chains, unusual source ASN changes, impossible travel, and repeated policy simulation calls. When the fused score crosses a policy boundary, the agent reasons across identity context, session lineage, privilege graph depth, and adjacent account exposure. The response applies short-lived token revocation, conditional access tightening, and temporary deny statements scoped to high-risk resources. Each transition is persisted with timeline snapshots, token IDs, and IAM diff artifacts. Staged revocation windows with service-principal allowlists and rollback checkpoints guard against interrupting legitimate automation paths.

Distributed Denial-of-Service Progression. The system monitors rapid rises in packet entropy, SYN imbalance, connection churn, and edge-to-origin ratio anomalies. The agent reasons across capacity baselines, campaign velocity, and user-impact indicators to avoid overreacting to marketing traffic spikes. Adaptive rate controls, perimeter hardening rules, and selective upstream scrubbing escalation are applied, each persisted with per-minute risk traces and mitigated versus dropped flow summaries. Progressive throttling with canary exemptions and monitored rollback timers prevent degrading legitimate burst traffic.

Lateral Movement in Virtual Private Clouds. The system monitors east-west scan signatures, unusual security-group mutations, and atypical service-to-service trust hops. The agent reasons across topology distance, trust boundary crossings, and process ancestry to distinguish maintenance from intrusion. Micro-segmentation enforcement, temporary route constraints, and host-level isolation recommendations are applied, persisted with graph snapshots and blast-radius estimates. Quarantine by service ring with dependency-aware isolation prevents disrupting shared-state workloads.

Data Exfiltration Through Stealth Channels. The system monitors small but persistent egress bursts, anomalous object read cadence, and destination novelty scores. The agent reasons across data sensitivity labels, user intent history, and destination reputation. Egress policy tightening, copy-operation interception, and mandatory justification workflows are applied, persisted with object access maps and transfer deltas. Job identity profiling and recurring transfer baselines with dual-approval exception windows guard against blocking legitimate backup or analytics jobs.

Cloud Control Plane Reconnaissance. The system monitors sudden service enumeration, Describe and List API sweeps, and broad region fan-out. The agent reasons across role purpose, historical admin behavior, and sequence patterns to classify reconnaissance intent. Risk-tiered alerting, API rate shaping, and policy challenge prompts are applied, persisted with API sequence replays and inferred objective tags.

UEBA Drift and Insider Misuse. The system monitors off-hours administrative actions, sudden privilege exercise spikes, and unusual data-domain transitions. The agent reasons across role tenure, project lifecycle context, and peer-group behavior to grade deviation significance. Step-up authentication, temporary privilege bounds, and manager-visible risk notifications are applied. Incident-mode toggles and emergency-role attestations prevent inflexible controls from penalizing legitimate incident responders.

Supply Chain and Dependency Risk. The system monitors new package signatures, sudden checksum drift, and unusual build-time network destinations. The agent reasons across release provenance, package trust history, and environment exposure. Build gate hardening, artifact quarantine, and provenance validation enforcement are applied, persisted with hash lineage and software bill-of-material snapshots. Sandbox verification lanes and emergency override policies prevent halting urgent production patching.

Ransomware-Like Encryption Behavior. The system monitors high-frequency file rewrites, entropy spikes in object versions, and endpoint command burst patterns. The agent reasons across workload purpose, expected cryptographic operations, and identity confidence. Write-rate limiting, snapshot lock activation, and endpoint network segmentation are applied, persisted with version-chain timelines and process trees. Application-aware allowlists and staged confirmation against multiple telemetry streams prevent premature lock enforcement on lawful bulk transformation jobs.

Container Escape and Runtime Tampering. The system monitors unexpected capability use, host namespace access attempts, and privileged mount operations. The agent reasons across image policy compliance, orchestration intent, and node-level anomaly context. Pod eviction, node cordon workflows, and runtime policy tightening are applied, persisted with admission logs and runtime traces. Zone-aware evacuation with workload priority classes and autoscaling coordination prevents blanket node cordons from reducing service availability.

XI. Limitations and Future Directions

Despite strong scenario performance, the current system has limitations. Controlled datasets cannot fully replicate the temporal complexity and adversarial adaptation seen in long-running production environments. Thresholds tuned on one environment may drift when workload patterns change, and model assumptions may degrade under new traffic compositions. The architecture addresses some of this through memory

feedback and confidence penalties, but robust generalization still requires continuous validation and periodic retraining under carefully versioned procedures.

Future work should prioritize three dimensions. First, multi-region correlation [9] can improve campaign-level visibility and reduce fragmented decisions in distributed cloud estates. Second, richer causal attribution can strengthen explainability by linking indicators to likely attack objectives rather than only anomaly magnitude. Third, semi-supervised feedback pipelines could accelerate adaptation by learning from analyst-confirmed outcomes without requiring full labeled datasets. These directions would further align autonomous response speed with operational confidence and governance quality.

XII. Conclusion

This paper presented a practical hybrid threat detection framework that combines IDS and UEBA scoring, policy-aware fusion, and constrained agentic reasoning into a single operational pipeline. The system is designed to improve decision quality, reduce analyst burden, and support explainable autonomous response with clear governance boundaries. Implementation and evaluation results indicate that cross-domain correlation and structured reasoning can materially improve operational usefulness compared to single-stream detection alone.

The broader contribution is methodological: cybersecurity automation works best when statistical detection, decision policy, and human trust mechanisms are co-designed rather than assembled independently. By making each decision traceable and each action bounded, the architecture provides a realistic path from monitoring-centric operations to responsible autonomy in cloud security environments.

References

[1] F. T. Liu, K. M. Ting, and Z.-H. Zhou, "Isolation Forest," *Proc. IEEE ICDM*, 2008.

[2] S. Yao et al., "ReAct: Synergizing Reasoning and Acting in Language Models," *ICLR*, 2023.

[3] S. Baral, S. Saha, and A. Haque, "Autonomous Cyber Incident Response Using Reasoning and Action," *IEEE IWCMC*, 2025.

[4] X. Lin, G. Avina, and J. Santoyo, "Reducing False Alerts in Cybersecurity Threat Detection Using Generative AI," 2025.

[5] C. Djidjev, "siForest: Detecting Network Anomalies with Set-Structured Isolation Forest," *arXiv*, 2025.

[6] S. Zehra et al., "DeSFAM: AI-Driven Framework for Securing Cloud Containers," *IEEE Access*, 2025.

[7] AWS, "CloudTrail User Guide," Amazon Web Services Documentation, 2025.

[8] NIST, "Guide to Intrusion Detection and Prevention Systems," NIST SP 800-94.

[9] ENISA, "Threat Landscape Report," European Union Agency for Cybersecurity, 2025.

[10] MITRE, "ATT&CK for Enterprise Matrix," MITRE Corp.